



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Gitea CVE-2026-60004 KEV Remote Code Execution Priority - 2026-08-28

Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-08-28
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Gitea CVE-2026-60004 KEV Remote Code Execution Priority - 2026-08-28 - Vulnerability Threat Intelligence Report

Published: 2026-08-28 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Vulnerability Metadata
5. Vulnerability Details
6. Tactics, Techniques, and Procedures
7. Infrastructure, Indicators, and Observables
8. Aviation / Aerospace Sector Impact
9. Detection Engineering
 - 9.1. Detection Logic Summary
10. Threat Hunting
 - 10.1. Hunt Hypotheses
11. Risk Assessment
12. Recommended Actions
13. References

Gitea CVE-2026-60004 KEV Remote Code Execution Priority - 2026-08-28

1. Executive Summary

CISA reportedly added Gitea CVE-2026-60004 to KEV on 2026-08-25 with an urgent remediation window. The issue matters beyond public Git hosting because internal developer platforms often contain secrets, deployment automation, and supplier collaboration paths; compromise can become a software-supply-chain incident.

Lost Boys Cyber selected this item for the 2026-08-28 daily automated intelligence coverage. This report is source-backed and intentionally avoids unsupported attribution or victim-impact claims where public reporting is incomplete.

2. Intelligence Requirements

Requirement	Why It Matters	Priority
Confirm affected assets and owners	Prevents generic reporting from missing exposed production systems.	High
Validate patch/mitigation and compensating controls	Reduces time-to-remediation for internet-facing and high-trust tiers.	High
Review identity and supplier paths	Many modern incidents propagate through valid credentials, federation, SaaS, or supplier access.	Medium-High
Preserve telemetry for incident review	Enables triage if exploitation, ransomware, or data theft indicators emerge.	High

3. Source Review & Confidence

Source	Contribution	Confidence
[1] CISA KEV Catalog	Authoritative exploitation-priority source.	Medium-High
[2] Gitea Security Advisory GHSA-rcr6-4jqh-j84m	Vendor/project advisory reference.	Medium-High
[3] NVD CVE-2026-60004	CVE metadata reference.	Medium-High
[4] Gitea Releases	Patch/version validation source.	Medium-High

Confidence is medium for tactical claims and medium-high for defender prioritization. Source windows were expanded to seven days or longer where same-day primary technical reporting was limited.

4. Vulnerability Metadata

Field	Value
CVE / Identifier	CVE-2026-60004
Public Status	Public reporting/advisory references available at collection time; exploitation status should be confirmed against CISA KEV/vendor data before enforcement actions.
Primary Risk	Remote code execution, authentication bypass, command execution, or platform compromise depending on affected product

	and deployment.
Exposure Priority	Internet-facing, externally federated, supplier-accessible, or privileged-management deployments first.
Current-Day Selection Rationale	Included in the 2026-08-28 daily priority set because public reporting indicates active defender relevance and the affected platform class is commonly exposed.

5. Vulnerability Details

CISA reportedly added Gitea CVE-2026-60004 to KEV on 2026-08-25 with an urgent remediation window. The issue matters beyond public Git hosting because internal developer platforms often contain secrets, deployment automation, and supplier collaboration paths; compromise can become a software-supply-chain incident.

Defender Question	Practical Answer
What should be inventoried?	Product/version, exposure path, owner, compensating controls, available logs, and third-party access.
What should be patched first?	Internet-facing and privileged tiers, followed by partner-accessible and internal high-trust deployments.
What evidence should be preserved?	Access logs, process telemetry, authentication events, configuration snapshots, and any suspicious file drops or outbound connections.

6. Tactics, Techniques, and Procedures

Tactic	Likely Behavior	Defensive Signal
Initial Access	Exploited public application, valid credentials, phishing, supplier access, or vulnerable edge/service technology.	New login geography, rare URL paths, error spikes, new sessions from hosting/VPN networks.
Execution	Service-spawned shell, script interpreter, workflow automation, or remote management tooling.	Suspicious child process from service parent; unusual command line or LOLBin use.
Persistence	Web shell, scheduled task, OAuth grant, token reuse, service account, or new local/admin account.	New autoruns, rare OAuth consent, local user creation, unexpected token use.
Defense Evasion	Living-off-the-land, trusted cloud/SaaS APIs, log clearing, disabling security controls.	Security tool tamper events, audit-log gaps, uncommon admin operations.
Collection / Exfiltration	Archive creation, database export, repository cloning, mailbox download, cloud bulk export.	Compression spikes, large downloads, rare remote destinations, unusual API pagination.
Impact	Ransomware, extortion pressure, service outage, fraud, or operational disruption.	Ransom notes, mass encryption, business application unavailability, helpdesk surges.

7. Infrastructure, Indicators, and Observables

Observable Type	Current Public Status	Collection Guidance
-----------------	-----------------------	---------------------

Hard IOCs	No complete authoritative IOC set was available for all cited public sources at drafting time.	Prefer vendor/government IOCs; avoid operationalizing unsourced leak-site or social-media artifacts.
CVEs / Affected Tech	CVE-2026-60004	Track asset inventory, SBOM/CMDB ownership, and externally reachable versions.
Accounts / Tokens	Identity abuse is plausible for this topic class.	Review privileged sessions, OAuth grants, service accounts, API keys, and dormant users.
Network Destinations	Use internal telemetry and trusted advisories for destination allow/block decisions.	Alert on first-seen egress from application, repository, identity, and admin tiers.

8. Aviation / Aerospace Sector Impact

Sector Dimension	Assessment
Affected Segment	Airlines, airports, aerospace and defense manufacturers, MRO providers, satellite/space-system operators, aviation software factories, and travel/reservation ecosystem partners depending on the affected technology or threat pattern.
Operational Relevance	CISA reportedly added Gitea CVE-2026-60004 to KEV on 2026-08-25 with an urgent remediation window. The issue matters beyond public Git hosting because internal developer platforms often contain secrets, deployment automation, and supplier collaboration paths; compromise can become a software-supply-chain incident. For aviation environments, incident impact can extend from enterprise IT into crew scheduling, passenger processing, maintenance coordination, supplier exchange, and operational decision support even when flight-safety systems are not directly targeted.
Likely Exposure Paths	Exposed internet-facing services, supplier remote access, identity federation, developer platforms, SaaS collaboration, passenger/loyalty applications, maintenance networks, airport OT support systems, and satellite-dependent communication workflows.
Third-Party / Supply Chain Considerations	Include ground handlers, reservation platforms, MRO vendors, avionics suppliers, logistics providers, MSPs, identity providers, and aerospace software suppliers in scoping and notification workflows.
Defender Actions	Validate asset ownership, segment critical aviation operations, verify MFA and conditional access, preserve logs, test backup recovery, review supplier access, and run the hunts in this report over at least 14-30 days.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Service process launching shell/script interpreter	EDR process telemetry	Catch exploitation or automation abuse.
Rare outbound connection from server/engineering tier	EDR, firewall, proxy, DNS	Surface payload retrieval or exfiltration staging.
Bulk archive or repository export behavior	EDR/file/SaaS audit logs	Detect collection before theft/extortion.
Suspicious OAuth grant or impossible travel	Identity provider logs	Detect account takeover or SaaS persistence.
<pre> title: LBC Daily Threat Service-Originated Shell Activity id: lbc-daily-threat-service-shell-2026-08-28 status: experimental description: Detects suspicious shell/script execution spawned by common service or application parents during daily threat review triage. logsource: product: windows category: process_creation detection: service_parent: ParentImage contains: - '\w3wp.exe' - '\java.exe' - '\nginx.exe' - '\httpd.exe' - '\gitea.exe' - '\sqlservr.exe' - '\tomcat' suspicious_child: Image endswith: - '\cmd.exe' - '\powershell.exe' - '\pwsh.exe' - '\rundll32.exe' - '\wscript.exe' - '\cscript.exe' condition: service_parent and suspicious_child fields: - UtcTime - Computer - ParentImage - Image - CommandLine level: high DeviceProcessEvents where Timestamp > ago(14d) where InitiatingProcessFileName has_any ("w3wp.exe", "java.exe", "nginx", "httpd", "gitea", "sqlservr.exe", "tomcat") where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe", "rundll32.exe", "wscript.exe", "cscript.exe", "bash", "sh", "python.exe") project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName </pre>		

10. Threat Hunting

10.1. Hunt Hypotheses

Hypothesis	Query Goal	Follow-Up
------------	------------	-----------

Exposed or high-trust service was abused for execution	Find rare service-child processes and command lines.	Pull process tree, parent network context, and web/access logs.
Data was staged before theft or extortion	Find repeated archive creation and unusual file access.	Validate user context and business justification; preserve staged artifacts.
Identity was abused for persistence or lateral movement	Find unusual sign-ins, OAuth grants, and privileged actions.	Revoke tokens, rotate credentials, review MFA/device posture.
<pre>DeviceFileEvents where Timestamp > ago(30d) where FileName endswith_any (".zip", ".7z", ".rar", ".tar", ".gz") summarize ArchiveEvents=count(), Paths=make_set(FolderPath, 20) by DeviceName, InitiatingProcessAccountName where ArchiveEvents >= 10 order by ArchiveEvents desc</pre>		
<pre>DeviceNetworkEvents where Timestamp > ago(30d) where InitiatingProcessFileName has_any ("w3wp.exe", "java.exe", "nginx", "httpd", "gitea", "sqlservr.exe", "tomcat") summarize Connections=count(), RemoteIPs=make_set(RemoteIP, 25), RemoteUrls=make_set(RemoteUrl, 25) by DeviceName, InitiatingProcessFileName where Connections > 20 or array_length(RemoteIPs) > 10</pre>		
<pre>index=edr sourcetype=process earliest=-30d (parent_process_name IN (w3wp.exe, java.exe, nginx.exe, httpd.exe, gitea.exe, sqlservr.exe, tomcat.exe)) (process_name IN (cmd.exe, powershell.exe, pwsh.exe, rundll32.exe, wscript.exe, cscript.exe, bash, sh, python.exe)) stats count values(process) as commands values(user) as users by host parent_process_name process_name where count > 0</pre>		

11. Risk Assessment

Risk	Likelihood	Impact	Notes
Initial compromise of exposed service or account	Medium	High	Prioritize internet-facing and third-party-accessible assets.
Data theft / extortion	Medium	High	Public claims require validation but should trigger egress and staging review.
Operational disruption	Medium	High	Aviation, healthcare, manufacturing, finance, logistics, and government services require resilience checks.
Supplier propagation	Medium	Medium-High	Shared platforms and managed services can spread exposure beyond the named organization.

12. Recommended Actions

Priority	Owner	Action
P0	SOC	Run the included hunts over 14-30 days

		and preserve evidence for incident review.
P0	Vulnerability / Platform	Validate patch state and compensating controls for affected services and high-trust integrations.
P1	IAM	Review privileged accounts, OAuth grants, service accounts, API keys, and MFA/conditional-access posture.
P1	Network / Cloud	Review first-seen egress, exposed management paths, and segmentation around critical services.
P2	Resilience / GRC	Confirm offline backups, supplier communications, incident communications, and executive briefing paths.

13. References

- [1] CISA KEV Catalog: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- [2] Gitea Security Advisory GHSA-rcr6-4jqh-j84m: <https://github.com/go-gitea/gitea/security/advisories/GHSA-rcr6-4jqh-j84m>
- [3] NVD CVE-2026-60004: <https://nvd.nist.gov/vuln/detail/CVE-2026-60004>
- [4] Gitea Releases: <https://github.com/go-gitea/gitea/releases>